Master’s Project Pilot

Christopher Wiggins

Wed Sep 9 2026

Project Purpose

The purpose of this project is to experimentally evaluate the security and operational effects of selected CIS Benchmark configuration controls on an Ubuntu 24.04 LTS server. Rather than treating benchmark compliance in simple pass/fail terms, the study will examine whether individual hardening controls materially alter the outcome of attacks against an otherwise equivalent system.

This project will compare a baseline Ubuntu 24.04 LTS installation against systems with selected CIS controls applied individually and in combination. Each system will be subjected to repeatable attack scenarios designed to measure whether a control prevents an attack, limits its effects, changes the attacker's required technique, or has no meaningful effect.

The study will also evaluate the operational consequences of each control. A security control may successfully interfere with an attack while simultaneously disrupting legitimate administrative or application behavior. These effects will be documented alongside the security results.

This pilot evaluates whether the selected CIS hardening recommendations produce repeatable changes in a defined attack outcome without unnecessarily disrupting legitimate system use.

Research Question

To what extent do selected CIS Benchmark configuration controls change the outcome of attacks against an Ubuntu 24.04 LTS system, and what operational consequences result from implementing those controls?

Supporting Research Questions

- Does a selected CIS control prevent exploitation, or does it primarily restrict attacker activity after initial compromise?
- Does the control reduce the attacker's ability to execute code, escalate privileges, establish persistence, access resources, or otherwise expand the compromise?
- Can an attacker bypass the control using commonly available alternative techniques?
- Does combining multiple related CIS controls provide a measurable security benefit beyond applying them individually?
- What legitimate system administration, software installation, application, or user workflows are disrupted by each control?
- Can observed attack effects be associated with particular CVEs, vulnerability classes, or attack techniques in a way that provides useful context beyond the CIS Benchmark itself?

Working Hypothesis

Systems configured with selected CIS Benchmark hardening controls will exhibit measurably reduced attack impact compared with an otherwise equivalent unhardened system, but the effectiveness and operational cost of the controls will vary substantially by control and attack technique.

More specifically, controls that restrict filesystem behavior, privileges, or execution are expected to be more effective at limiting post-exploitation activity than at preventing the initial exploitation of a vulnerable service.

Some controls are also expected to be bypassable. A control should therefore not automatically be classified as ineffective when bypass is possible. Instead, the experiment will measure whether the control increases the number, complexity, or prerequisites of the actions required by the attacker.

Independent Variable

The primary independent variable is the CIS hardening configuration applied to the system.

For example:

- No hardening control (baseline)
- /tmp mounted with nodev
- /tmp mounted with nosuid
- /tmp mounted with noexec
- /var/tmp with equivalent restrictions
- /dev/shm with equivalent restrictions
- Selected combinations of these controls

Only the control or control set under investigation should be intentionally changed between the baseline and experimental systems.

Dependent Variables

The dependent variables are the observable security and operational outcomes resulting from each configuration.

Security measurements may include:

- Initial exploitation success or failure
- Arbitrary command/code execution
- Execution of attacker-controlled files
- Privilege escalation
- Persistence
- Access to protected resources
- Ability to stage tools or payloads
- Ability to bypass the tested control
- Additional steps required to accomplish the attack objective
- Changes in attack technique required

Operational measurements may include:

- Application failures
- Package installation or upgrade failures
- Administrative script failures
- Temporary-file failures
- Service startup failures
- Changes to normal administrator workflows
- Additional configuration necessary to maintain legitimate functionality

Primary Attack Outcomes:

Each attack trial should be classified according to its final result rather than simply as "vulnerable" or "not vulnerable."

1. Prevented

The attack cannot achieve its intended objective because of the tested control.

2. Constrained

Initial compromise succeeds, but the control prevents or substantially limits a later stage of the attack.

For example, an attacker obtains a shell but cannot execute a staged binary from the intended temporary filesystem.

3. Bypassed

The original attack path is blocked, but the attacker can achieve the same objective using an alternative technique.

The bypass method and additional requirements should be recorded.

4. Delayed / Increased Complexity

The attack remains possible, but the control requires additional steps, knowledge, tools, privileges, or system interaction.

5. Unaffected

There is no meaningful difference between the hardened and baseline systems for the tested attack.

These categories allow the experiment to capture an important distinction that a simple pass/fail measurement would miss: a control may provide security value even when it does not completely prevent compromise.

Operational Impact Outcome

Each tested control should also receive an operational-impact classification:

None: No observed effect on legitimate operation.

Minor: A legitimate workflow requires a simple adjustment or workaround.

Moderate: Common administrative or application behavior fails and requires configuration changes.

Severe: The control prevents an important service or expected system function from operating normally.

The exact failure, workaround, and affected software should be recorded rather than relying exclusively on the categorical rating.

Experimental Comparison and Scope

The fundamental experimental structure is:

Control System

Ubuntu 24.04 LTS with the test filesystems present but without the CIS hardening option being evaluated.

versus

Experimental System

An otherwise equivalent Ubuntu 24.04 LTS system with the selected CIS control applied.

Each attack should first be demonstrated against the baseline system. This establishes that the attack scenario is functional before testing whether a hardening control changes its outcome.

Experimental Unit

A trial consists of:

Known VM state → selected configuration → defined attack → observed outcome → restoration to known state

VM snapshots or clones should be used to return the system to the same initial condition before subsequent trials. This prevents artifacts from previous attacks from contaminating later results.

Where practical, trials should be repeated to distinguish reproducible control effects from incidental system behavior.

Proposed Dataset

Each experimental observation can ultimately become a structured record containing fields such as:

CIS Control → System Configuration → Attack Technique → CVE/CWE (when applicable) → Baseline Outcome → Hardened Outcome → Bypass → Operational Impact → Evidence → Confidence

For example:

CIS /tmp noexec control → arbitrary code execution scenario → baseline payload executes → hardened payload cannot execute directly from /tmp → alternative execution technique investigated → administrative impact recorded

This structure connects benchmark compliance to empirical security behavior rather than merely reporting whether a configuration passes a compliance scanner.

Expected Contribution

The expected contribution of the project is not to demonstrate that CIS Benchmarks are universally effective or ineffective. Instead, the project seeks to provide empirical context for selected controls.

The resulting data should help answer a more useful administrative question than "Does this system pass the CIS Benchmark?"

The question becomes:

What security outcome does this control change, under what circumstances does it change it, how easily can its protection be bypassed, and what does implementing it cost operationally?

This information can ultimately supplement existing compliance-scanning tools such as OpenSCAP by providing administrators with security-effectiveness and operational-impact context when evaluating remediation recommendations.

Some examples of “control” configuration commands on an Ubuntu VM

Linux Distribution Ubuntu Server 24.04 LTS

Hypervisor :: Proxmox VE

Target VM :: Ubuntu Server 24.04

Test VM :: TBD

Benchmark :: TBD

Attack Scenario :: Unauthorized SSH access through password guessing

Primary Controls :: TBD

Repetitions :: Minimum 5 per condition

Repository Layout

Repo Layout

```
.
├── README.md
├── data
├── evidence
├── img
├── init.md
├── init.org
├── logs
└── scripts
```

6 directories, 3 files

Environment

Operating System

SSH status and configuration

```
$ systemctl status ssh --no-pager
● ssh.service - OpenBSD Secure Shell server
     Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset:
                     enabled)
     Active: active (running) since Wed 2026-09-09 17:21:15 UTC; 3min 40s ago
TriggeredBy: ● ssh.socket
       Docs: man:sshd(8)
             man:sshd_config(5)
    Process: 969 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
   Main PID: 971 (sshd)
```

```
      Tasks: 1 (limit: 9432)
     Memory: 6.7M (peak: 7.5M)
        CPU: 209ms
     CGroup: /system.slice/ssh.service
             └─971 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Sep 09 17:21:15 lab sshd[971]: Server listening on :: port 22.
Sep 09 17:21:15 lab systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
Sep 09 17:21:15 lab sshd[972]: Connection closed by authenticating user cis
100.85.132.4 port 57886 [preauth]
Sep 09 17:21:16 lab sshd[974]: Connection closed by authenticating user cis
100.85.132.4 port 57890 [preauth]
Sep 09 17:21:18 lab sshd[976]: Accepted password for cis from 100.85.132.4 port
57896 ssh2
Sep 09 17:21:18 lab sshd[976]: pam_unix(sshd:session): session opened for user
cis(uid=1000) by cis(uid=0)
Sep 09 17:21:27 lab sshd[1173]: Accepted publickey for cis from 100.85.132.4
port 57950 ssh2: ED25519 SHA256:39YikF+9P5ln0osyDzzM5H1VvgGn+RbsXuTsU9RtsFQ
Sep 09 17:21:27 lab sshd[1173]: pam_unix(sshd:session): session opened for user
cis(uid=1000) by cis(uid=0)
Sep 09 17:24:55 lab sshd[1661]: Accepted publickey for cis from 100.85.132.4
port 57898 ssh2: ED25519 SHA256:39YikF+9P5ln0osyDzzM5H1VvgGn+RbsXuTsU9RtsFQ
Sep 09 17:24:55 lab sshd[1661]: pam_unix(sshd:session): session opened for user
cis(uid=1000) by cis(uid=0)

$ ss -lntp | grep ':22'
LISTEN 0      4096                       0.0.0.0:22         0.0.0.0:*
LISTEN 0      4096                          [::]:22            [::]:*

$ sudo -n sshd -T | grep -E \
'passwordauthentication|maxauthtries|permitrootlogin|allowusers|allowgroups \
|denyusers|denygroups'

maxauthtries 6
permitrootlogin without-password
passwordauthentication yes
```

Openscap

This is the version of OpenSCAP I am running:

initial OpenSCAP version

```
$ oscap --version
OpenSCAP command line tool (oscap) 1.3.9
Copyright 2009--2023 Red Hat Inc., Durham, North Carolina.

==== Supported specifications ====
SCAP Version: 1.3
XCCDF Version: 1.2
OVAL Version: 5.11.1
CPE Version: 2.3
CVSS Version: 2.0
CVE Version: 2.0
Asset Identification Version: 1.1
Asset Reporting Format Version: 1.1
CVRF Version: 1.1

==== Capabilities added by auto-loaded plugins ====
SCE Version: 1.0 (from libopenscap_sce.so.25)

==== Paths ====
Schema files: /usr/share/openscap/schemas
Default CPE files: /usr/share/openscap/cpe

==== Inbuilt CPE names ====
Red Hat Enterprise Linux - cpe:/o:redhat:enterprise_linux:-
Red Hat Enterprise Linux 5 - cpe:/o:redhat:enterprise_linux:5
Red Hat Enterprise Linux 6 - cpe:/o:redhat:enterprise_linux:6
Red Hat Enterprise Linux 7 - cpe:/o:redhat:enterprise_linux:7
Red Hat Enterprise Linux 8 - cpe:/o:redhat:enterprise_linux:8
Community Enterprise Operating System 5 - cpe:/o:centos:centos:5
Community Enterprise Operating System 6 - cpe:/o:centos:centos:6
Community Enterprise Operating System 7 - cpe:/o:centos:centos:7
Community Enterprise Operating System 8 - cpe:/o:centos:centos:8
Fedora 32 - cpe:/o:fedoraproject:fedora:32
Fedora 33 - cpe:/o:fedoraproject:fedora:33
Fedora 34 - cpe:/o:fedoraproject:fedora:34
Fedora 35 - cpe:/o:fedoraproject:fedora:35

==== Supported OVAL objects and associated OpenSCAP probes ====
OVAL family   OVAL object                  OpenSCAP probe
----------    ----------                  ----------
independent   environmentvariable         probe_environmentvariable
independent   environmentvariable58       probe_environmentvariable58
independent   family                      probe_family
```

```
independent   filehash                  probe_filehash (MD5, SHA-1)
independent   filehash58                probe_filehash58 (MD5, SHA-1, SHA-224,
                                                        SHA-256, SHA-384, SHA-512)
independent   sql                       probe_sql
independent   sql57                     probe_sql57
independent   system_info               probe_system_info
independent   textfilecontent           probe_textfilecontent
independent   textfilecontent54         probe_textfilecontent54
independent   variable                  probe_variable
independent   xmlfilecontent            probe_xmlfilecontent
independent   yamlfilecontent           probe_yamlfilecontent
linux         dpkginfo                  probe_dpkginfo
linux         iflisteners               probe_iflisteners
linux         inetlisteningservers      probe_inetlisteningservers
linux         partition                 probe_partition
linux         rpminfo                   probe_rpminfo
linux         rpmverify                 probe_rpmverify
linux         rpmverifyfile             probe_rpmverifyfile
linux         rpmverifypackage          probe_rpmverifypackage
linux         selinuxboolean            probe_selinuxboolean
linux         selinuxsecuritycontext    probe_selinuxsecuritycontext
linux         systemdunitdependency     probe_systemdunitdependency
linux         systemdunitproperty       probe_systemdunitproperty
linux         fwupdsecattr              probe_fwupdsecattr
unix          dnscache                  probe_dnscache
unix          file                      probe_file
unix          fileextendedattribute     probe_fileextendedattribute
unix          interface                 probe_interface
unix          password                  probe_password
unix          process                   probe_process
unix          process58                 probe_process58
unix          routingtable              probe_routingtable
unix          runlevel                  probe_runlevel
unix          shadow                    probe_shadow
unix          symlink                   probe_symlink
unix          sysctl                    probe_sysctl
unix          uname                     probe_uname
unix          xinetd                    probe_xinetd
```

Experiment

One of the main pain points of the Ubuntu 24.04 LTS CIS benchmark is mount options for filesystems. ‘noexec, nosuid, nodev’ are all common restrictive options for filesystem mounts that administrators avoid, particularly for /tmp, /var/tmp, and /dev/shm, because noexec can collide with software behavior.

Condition C0

Comparison Baseline

Control A :: Disabled

Control B :: Disabled

Verify Configuration

Verify configuration

```
$ cat /etc/os-release | tee os-release.txt
PRETTY_NAME="Ubuntu 24.04.5 LTS"
NAME="Ubuntu"
VERSION_ID="24.04"
VERSION="24.04.5 LTS (Noble Numbat)"
VERSION_CODENAME=noble
ID=ubuntu
ID_LIKE=debian
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://ubuntu.com/legal/terms-and-policies/privacy-policy"
UBUNTU_CODENAME=noble
LOGO=ubuntu-logo

$ uname -a | tee uname.txt
Linux lab 6.8.0-139-generic #139-Ubuntu SMP PREEMPT_DYNAMIC
Sat Aug  1 03:52:05 UTC 2026 x86_64 x86_64 x86_64 GNU/Linux

$ uname -r
6.8.0-139-generic

$ hostnamectl
 Static hostname: lab
       Icon name: computer-vm
         Chassis: vm
      Machine ID: e80028c5c798486599e040a075b43163
         Boot ID: 2c54934ec4294a3db84182afcac70799
  Virtualization: kvm
Operating System: Ubuntu 24.04.5 LTS
```

```
          Kernel: Linux 6.8.0-139-generic
    Architecture: x86-64
 Hardware Vendor: QEMU
  Hardware Model: Standard PC _i440FX + PIIX, 1996_
Firmware Version: rel-1.17.0-0-gb52ca86e094d-prebuilt.qemu.org
   Firmware Date: Tue 2014-04-01
    Firmware Age: 12y 5month 1w 2d

$ dpkg --print-architecture
amd64

$ lsmod
Module                  Size  Used by
tls                   155648  0
tcp_diag               12288  0
inet_diag              28672  1 tcp_diag
xt_connmark            12288  6
xt_conntrack           12288  4
xt_MASQUERADE          16384  2
xt_tcpudp              16384  0
xt_mark                12288  2
nft_compat             20480  14
nft_chain_nat          12288  2
nf_nat                 61440  2 nft_chain_nat,xt_MASQUERADE
nf_conntrack          200704  4 xt_conntrack,nf_nat,xt_connmark,xt_MASQUERADE
nf_defrag_ipv6         24576  1 nf_conntrack
nf_defrag_ipv4         12288  1 nf_conntrack
qrtr                   53248  2
nf_tables             380928  109 nft_compat,nft_chain_nat
cfg80211             1368064  0
binfmt_misc            24576  1
i2c_piix4              32768  0
vmgenid                12288  0
input_leds             12288  0
joydev                 32768  0
mac_hid                12288  0
serio_raw              20480  0
sch_fq_codel           24576  3
dm_multipath           45056  0
msr                    12288  0
efi_pstore             12288  0
nfnetlink              20480  4 nft_compat,nf_tables
dmi_sysfs              24576  0
qemu_fw_cfg            24576  0
ip_tables              32768  0
x_tables               65536  7 xt_conntrack,nft_compat,xt_tcpudp,xt_connmark,
                                 ip_tables,xt_MASQUERADE,xt_mark
autofs4                57344  2
```

```
btrfs                2060288  0
blake2b_generic        24576  0
raid10                 77824  0
raid456               196608  0
async_raid6_recov      20480  1 raid456
async_memcpy           16384  2 raid456,async_raid6_recov
async_pq               20480  2 raid456,async_raid6_recov
async_xor              16384  3 async_pq,raid456,async_raid6_recov
async_tx               16384  5 async_pq,async_memcpy,async_xor,raid456,
                                 async_raid6_recov
xor                    20480  2 async_xor,btrfs
raid6_pq              126976  4 async_pq,btrfs,raid456,async_raid6_recov
libcrc32c              12288  5 nf_conntrack,nf_nat,btrfs,nf_tables,raid456
raid1                  61440  0
raid0                  24576  0
sha256_ssse3           32768  0
sha1_ssse3             32768  0
psmouse               217088  0
bochs                  20480  0
drm_vram_helper        24576  1 bochs
drm_ttm_helper         12288  2 bochs,drm_vram_helper
ttm                   110592  2 drm_vram_helper,drm_ttm_helper
pata_acpi              12288  0
floppy                131072  0
hid_generic            12288  0
usbhid                 77824  0
hid                   180224  2 usbhid,hid_generic
aesni_intel           356352  0
crypto_simd            16384  1 aesni_intel
cryptd                 24576  1 crypto_simd

$ lscpu
Architecture:                         x86_64
CPU op-mode(s):                       32-bit, 64-bit
Address sizes:                        40 bits physical, 48 bits virtual
Byte Order:                           Little Endian
CPU(s):                               2
On-line CPU(s) list:                  0,1
Vendor ID:                            GenuineIntel
Model name:                           QEMU Virtual CPU version 2.5+
CPU family:                           15
Model:                                107
Thread(s) per core:                   1
Core(s) per socket:                   2
Socket(s):                            1
Stepping:                             1
BogoMIPS:                             6199.99
Flags:                                fpu de pse tsc msr pae mce cx8 apic
```

```
sep mtrr pge mca cmov pat pse36 clflush mmx fxsr sse sse2 ht syscall nx lm
constant_tsc nopl xtopology cpuid tsc_known_freq pni ssse3 cx16 sse4_1 sse4_2
x2apic popcnt aes hypervisor lahf_lm cpuid_fault pti
Hypervisor vendor:                       KVM
Virtualization type:                     full
L1d cache:                               64 KiB (2 instances)
L1i cache:                               64 KiB (2 instances)
L2 cache:                                8 MiB (2 instances)
L3 cache:                                16 MiB (1 instance)
NUMA node(s):                            1
NUMA node0 CPU(s):                       0,1
Vulnerability Gather data sampling:      Not affected
Vulnerability Indirect target selection: Mitigation; Aligned branch/return thunks
Vulnerability Itlb multihit:             KVM: Mitigation: VMX unsupported
Vulnerability L1tf:                      Mitigation; PTE Inversion
Vulnerability Mds:                       Vulnerable: Clear CPU buffers attempted,
                                            no microcode; SMT Host state unknown
Vulnerability Meltdown:                  Mitigation; PTI
Vulnerability Mmio stale data:           Unknown: No mitigations
Vulnerability Reg file data sampling:    Not affected
Vulnerability Retbleed:                  Not affected
Vulnerability Spec rstack overflow:      Not affected
Vulnerability Spec store bypass:         Vulnerable
Vulnerability Spectre v1:                Mitigation; usercopy/swapgs barriers
                                                and __user pointer sanitization
Vulnerability Spectre v2:                Mitigation; Retpolines; STIBP disabled;
                                         RSB filling; PBRSB-eIBRS Not affected;
                                         BHI Retpoline
Vulnerability Srbds:                     Not affected
Vulnerability Tsa:                       Not affected
Vulnerability Tsx async abort:           Not affected
Vulnerability Vmscape:                   Not affected

$ free -h
               total        used        free      shared  buff/cache   available
Mem:           7.8Gi       418Mi       6.9Gi       1.0Mi       702Mi       7.3Gi
Swap:          4.0Gi          0B       4.0Gi

$ lsblk -o NAME,SIZE,FSTYPE,MOUNTPOINTS,UUID
NAME    SIZE FSTYPE  MOUNTPOINTS UUID
sda     100G
├─sda1    1M
├─sda2   30G ext4    /           a64821cd-156f-4956-b42a-5852a2c43d57
├─sda3    1G ext4    /boot       7bc524d1-1805-427e-8e73-cf76e34febcb
├─sda4   20G ext4    /var        ca5d29bb-904d-4b9f-b66f-1a4cdbc95b5e
├─sda5    4G ext4    /tmp        6618f34a-c47b-492d-a28c-5a626918c278
├─sda6    4G ext4    /var/tmp    2e216aac-5469-4fe7-9811-3e90ea70e56a
└─sda7   41G ext4    /home       44464258-4e98-4126-b170-dc16429430a4
```

```
sr0     3.2G iso9660             2026-02-10-06-52-50-00

$ df -hT
Filesystem     Type   Size  Used Avail Use% Mounted on
tmpfs          tmpfs  795M 1020K  794M   1% /run
/dev/sda2      ext4    30G  6.4G   22G  23% /
tmpfs          tmpfs  3.9G     0  3.9G   0% /dev/shm
tmpfs          tmpfs  5.0M     0  5.0M   0% /run/lock
/dev/sda5      ext4   3.9G   68K  3.7G   1% /tmp
/dev/sda4      ext4    20G  457M   19G   3% /var
/dev/sda3      ext4   974M  104M  803M  12% /boot
/dev/sda7      ext4    41G   68K   38G   1% /home
/dev/sda6      ext4   3.9G   64K  3.7G   1% /var/tmp
tmpfs          tmpfs  795M   12K  795M   1% /run/user/1000

$ findmnt
TARGET                          SOURCE      FSTYPE      OPTIONS
/                               /dev/sda2   ext4        rw,relatime
├─/sys                          sysfs       sysfs       rw,nosuid,nodev,noexec,
                                                        relatime
│ ├─/sys/kernel/security        securityfs  securityfs  rw,nosuid,nodev,noexec,
                                                        relatime
│ ├─/sys/fs/cgroup              cgroup2     cgroup2     rw,nosuid,nodev,noexec,
                                                        relatime,nsdelegate,
                                                        memory_recursiveprot
│ ├─/sys/fs/pstore              pstore      pstore      rw,nosuid,nodev,noexec,
                                                        relatime
│ ├─/sys/fs/bpf                 bpf         bpf         rw,nosuid,nodev,noexec,
                                                        relatime,mode=700
│ ├─/sys/kernel/debug           debugfs     debugfs     rw,nosuid,nodev,noexec,
                                                        relatime
│ ├─/sys/kernel/tracing         tracefs     tracefs     rw,nosuid,nodev,noexec,
                                                        relatime
│ ├─/sys/fs/fuse/connections    fusectl     fusectl     rw,nosuid,nodev,noexec,
                                                        relatime
│ └─/sys/kernel/config          configfs    configfs    rw,nosuid,nodev,noexec,
                                                        relatime
├─/proc                         proc        proc        rw,nosuid,nodev,noexec,
                                                        relatime
│ └─/proc/sys/fs/binfmt_misc    systemd-1   autofs      rw,relatime,fd=32,pgrp=1,
                                                        timeout=0,minproto=5,
                                                        maxproto=5,direct,
                                                        pipe_ino=3277
│   └─/proc/sys/fs/binfmt_misc  binfmt_misc binfmt_misc rw,nosuid,nodev,noexec,
                                                        relatime
├─/dev                          udev        devtmpfs    rw,nosuid,relatime,
                                                        size=4024400k,
                                                        nr_inodes=1006100,
```

```
                                                    mode=755,inode64
│ ├─/dev/pts                  devpts      devpts     rw,nosuid,noexec,relatime,
                                                    gid=5,mode=620,
                                                    ptmxmode=000
│ ├─/dev/shm                  tmpfs       tmpfs      rw,nosuid,nodev,inode64
│ ├─/dev/hugepages            hugetlbfs   hugetlbfs  rw,nosuid,nodev,relatime,
                                                    pagesize=2M
│ └─/dev/mqueue               mqueue      mqueue     rw,nosuid,nodev,noexec,
                                                    relatime
├─/run                       tmpfs       tmpfs      rw,nosuid,nodev,noexec,
                                                    relatime,size=813248k,
                                                    mode=755,inode64
│ ├─/run/lock                tmpfs       tmpfs      rw,nosuid,nodev,noexec,
                                                    relatime,size=5120k,
                                                    inode64
│ └─/run/user/1000           tmpfs       tmpfs      rw,nosuid,nodev,relatime,
                                                    size=813244k,
                                                    nr_inodes=203311,
                                                    mode=700,uid=1000,
                                                    gid=1000,inode64
├─/tmp                       /dev/sda5   ext4       rw,relatime
├─/var                       /dev/sda4   ext4       rw,relatime
│ └─/var/tmp                 /dev/sda6   ext4       rw,relatime
├─/boot                      /dev/sda3   ext4       rw,relatime
└─/home                      /dev/sda7   ext4       rw,relatime
```

```
$ cat /etc/fstab
# /etc/fstab: static file system information.
#
# Use 'blkid' to print the universally unique identifier for a
# device; this may be used with UUID= as a more robust way to name devices
# that works even if disks are added and removed. See fstab(5).
#
# <file system> <mount point>   <type>  <options>       <dump>  <pass>
# / was on /dev/sda2 during curtin installation
/dev/disk/by-uuid/a64821cd-156f-4956-b42a-5852a2c43d57 / ext4 defaults 0 1
# /boot was on /dev/sda3 during curtin installation
/dev/disk/by-uuid/7bc524d1-1805-427e-8e73-cf76e34febcb /boot ext4 defaults 0 1
# /var was on /dev/sda4 during curtin installation
/dev/disk/by-uuid/ca5d29bb-904d-4b9f-b66f-1a4cdbc95b5e /var ext4 defaults 0 1
# /tmp was on /dev/sda5 during curtin installation
/dev/disk/by-uuid/6618f34a-c47b-492d-a28c-5a626918c278 /tmp ext4 defaults 0 1
# /var/tmp was on /dev/sda6 during curtin installation
/dev/disk/by-uuid/2e216aac-5469-4fe7-9811-3e90ea70e56a /var/tmp ext4 defaults 0 1
# /home was on /dev/sda7 during curtin installation
/dev/disk/by-uuid/44464258-4e98-4126-b170-dc16429430a4 /home ext4 defaults 0 1
/swap.img   none    swap    sw  0   0
```

```
# this is particularly interesting for our experiment
$ findmnt /tmp
TARGET SOURCE    FSTYPE OPTIONS
/tmp   /dev/sda5 ext4   rw,relatime

$ findmnt /var/tmp
TARGET   SOURCE    FSTYPE OPTIONS
/var/tmp /dev/sda6 ext4   rw,relatime

$ findmnt /dev/shm
TARGET   SOURCE FSTYPE OPTIONS
/dev/shm tmpfs  tmpfs  rw,nosuid,nodev,inode64

# network baseline
$ ip addr show
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group
                                                              default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: ens18: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP
                                                    group default qlen 1000
    link/ether bc:24:11:09:6f:1b brd ff:ff:ff:ff:ff:ff
    altname enp0s18
    inet 192.168.68.50/22 metric 100 brd 192.168.71.255 scope global dynamic ens18
       valid_lft 6049sec preferred_lft 6049sec
    inet6 fe80::be24:11ff:fe09:6f1b/64 scope link
       valid_lft forever preferred_lft forever

$ ip route show table all
default via 192.168.68.1 dev ens18 proto dhcp src 192.168.68.50 metric 100
45.20.253.17 via 192.168.68.1 dev ens18 proto dhcp src 192.168.68.50 metric 100
69.1.184.66 via 192.168.68.1 dev ens18 proto dhcp src 192.168.68.50 metric 100
69.1.184.67 via 192.168.68.1 dev ens18 proto dhcp src 192.168.68.50 metric 100
192.168.68.0/22 dev ens18 proto kernel scope link src 192.168.68.50 metric 100
192.168.68.1 dev ens18 proto dhcp scope link src 192.168.68.50 metric 100
209.244.0.3 via 192.168.68.1 dev ens18 proto dhcp src 192.168.68.50 metric 100
local 127.0.0.0/8 dev lo table local proto kernel scope host src 127.0.0.1
local 127.0.0.1 dev lo table local proto kernel scope host src 127.0.0.1
broadcast 127.255.255.255 dev lo table local proto kernel scope link src
                                                                  127.0.0.1
local 192.168.68.50 dev ens18 table local proto kernel scope host src
                                                                192.168.68.50
broadcast 192.168.71.255 dev ens18 table local proto kernel scope link src
                                                                192.168.68.50
fe80::/64 dev ens18 proto kernel metric 256 pref medium
```

```
local ::1 dev lo table local proto kernel metric 0 pref medium
local fe80::be24:11ff:fe09:6f1b dev ens18 table local proto kernel metric 0 pref
                                                                        medium
multicast ff00::/8 dev ens18 table local proto kernel metric 256 pref medium

$ ip link show
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN mode DEFAULT
                                                      group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
2: ens18: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP mode
                                                     DEFAULT group default qlen 1000
    link/ether bc:24:11:09:6f:1b brd ff:ff:ff:ff:ff:ff
    altname enp0s18

$ ss -lntup
Netid State  Recv-Q Send-Q            Local Address:Port PeerAddress:PortProcess
udp   UNCONN 0      0                    127.0.0.54:53         0.0.0.0:*
udp   UNCONN 0      0                 127.0.0.53%lo:53         0.0.0.0:*
udp   UNCONN 0      0           192.168.68.50%ens18:68         0.0.0.0:*
udp   UNCONN 0      0                       0.0.0.0:41641      0.0.0.0:*
udp   UNCONN 0      0                          [::]:41641         [::]:*
tcp   LISTEN 0      4096               100.113.20.90:46282      0.0.0.0:*
tcp   LISTEN 0      4096               127.0.0.53%lo:53         0.0.0.0:*
tcp   LISTEN 0      4096                     0.0.0.0:22         0.0.0.0:*
tcp   LISTEN 0      4096                  127.0.0.54:53         0.0.0.0:*
tcp   LISTEN 0      4096 [fd7a:115c:a1e0::f22f:145b]:34790          [::]:*
tcp   LISTEN 0      4096                        [::]:22            [::]:*

$ sudo -n ufw status verbose
Status: inactive

$ sudo -n nft list ruleset
table ip filter {
    chain ts-input {
        ip saddr 100.113.20.90 iifname "lo" counter packets 0 bytes 0 accept
        udp dport 41641 counter packets 13047 bytes 2034720 accept
    }

    chain ts-forward {
        meta mark & 0x00ff0000 == 0x00040000 counter packets 0 bytes 0 accept
    }

    chain INPUT {
        type filter hook input priority filter; policy accept;
        counter packets 26744 bytes 5696595 jump ts-input
    }

    chain FORWARD {
```

```
        type filter hook forward priority filter; policy accept;
        counter packets 0 bytes 0 jump ts-forward
    }
}
table ip nat {
    chain ts-postrouting {
        meta mark & 0x00ff0000 == 0x00040000 counter packets 0 bytes 0 #
        Warning: table ip filter is managed by iptables-nft, do not touch!
# Warning: table ip nat is managed by iptables-nft, do not touch!
# Warning: table ip6 filter is managed by iptables-nft, do not touch!
masquerade
    }

    chain POSTROUTING {
        type nat hook postrouting priority srcnat; policy accept;
        counter packets 269 bytes 23526 jump ts-postrouting
    }
}
table ip6 filter {
    chain ts-input {
        ip6 saddr fd7a:115c:a1e0::f22f:145b iifname "lo" counter packets 0
                                                                bytes 0 accept
        udp dport 41641 counter packets 0 bytes 0 accept
    }

    chain ts-forward {
        meta mark & 0x00ff0000 == 0x00040000 counter packets 0 bytes 0 accept
    }

    chain INPUT {
        type filter hook input priority filter; policy accept;
        counter packets 0 bytes 0 jump ts-input
    }

    chain FORWARD {
        type filter hook forward priority filter; policy accept;
        counter packets 0 bytes 0 jump ts-forward
    }
}
table ip6 nat {
    chain ts-postrouting {
        meta mark & 0x00ff0000 == 0x00040000 counter packets 0 bytes 0 xt
        target "MASQUERADE"
    }

    chain POSTROUTING {
        type nat hook postrouting priority srcnat; policy accept;
        counter packets 0 bytes 0 jump ts-postrouting
```

```
    }
}
table ip mangle {
    chain PREROUTING {
        type filter hook prerouting priority mangle; policy accept;
        ct state related,established ct mark and 0xff0000 != 0x0 counter packets
        574 bytes 59657 meta mark set ct mark and 0xff0000
    }

    chain OUTPUT {
        type route hook output priority mangle; policy accept;
        ct state new meta mark & 0x00ff0000 != 0x00000000 counter packets 267
        bytes 26430 ct mark set mark and 0xff0000
    }
}
table ip6 mangle {
    chain PREROUTING {
        type filter hook prerouting priority mangle; policy accept;
        ct state related,established ct mark and 0xff0000 != 0x0 counter packets
        0 bytes 0 meta mark set ct mark and 0xff0000
    }

    chain OUTPUT {
        type route hook output priority mangle; policy accept;
        ct state new meta mark & 0x00ff0000 != 0x00000000 counter packets 0
        bytes 0 ct mark set mark and 0xff0000
    }
}
# Warning: table ip6 nat is managed by iptables-nft, do not touch!
# Warning: XT target MASQUERADE not found
# Warning: table ip mangle is managed by iptables-nft, do not touch!
# Warning: table ip6 mangle is managed by iptables-nft, do not touch!
```

Legitimate access result

Notes:

Attack Result

Notes:

Logs

Log Baseline